auth.js

auth.js — Authentication and Session Management

- Purpose: Handles registration, login, logout, JWT issuance, and auth middlewares.
- Key exports: `router`, `requireAuth`, `requireOfficer`.
- Dependencies: bcrypt, jsonwebtoken, crypto, better-sqlite3 DB helpers.

Important Behaviors

- JWT cookie: Issued via `issueToken()` with httpOnly cookie `ft_token`, expires in 7 days (`JWT_EXPIRES = '7d'`).
- Session validation: On every authenticated route, `requireAuth` verifies the JWT and checks the session in the `sessions` table by hashing the token (`sha256`) and ensuring `expires_at` is in the future.
- Officer-only guard: `requireOfficer` wraps `requireAuth` and enforces `role === 'officer'`.

Anti-Brute-Force (15-minute window)

- Function `checkBruteForce(email, ip)` counts failed login attempts in the last 15 minutes; blocks if ≥ 10.
- Location in code: Lines ~95–103 (see project reference).
- Effect: Even with correct credentials later, a user may get 429 until the 15-minute window passes if 10+ failed attempts occurred recently.

Endpoints

- POST `/api/auth/register`
  - Validates name/email/password, enforces password strength, checks duplicate email.
  - Creates `users` row with generated `unique_code` and `account_number`.
  - Adds a welcome notification.
  - Issues session token cookie.
- POST `/api/auth/login`
  - Runs `checkBruteForce` first (15-min window).
  - Validates credentials with bcrypt.
  - Updates `last_active`, logs attempts (success/failure in `login_attempts`).
  - Issues session token cookie.

- POST `/api/auth/logout`
  - Deletes session by token hash and clears cookie.
- GET `/api/auth/me` and `/api/auth/check`
  - Returns current user data / quick auth confirmation.

Impact on System

- Central gatekeeper for all authenticated flows (transactions, social, fraud officer endpoints).
- The 15-minute lockout and the global auth rate limiter (defined in `server/index.js`) together prevent excessive auth traffic and brute-force behavior.